

Software Engineering 1

Risikomanagement

25.11.2025





Risikomanagement

Was sind Risiken in einem Projekt?

Risiken sind potenzielle Probleme

Zwei Merkmale von Risiken:

- Ungewissheit
- Verlust

Typische Folge:

- Erhöhte Kosten
- Verzögerung des Zeitplans
- Schlechte Ergebnisse (Funktionalität, Qualität)
- Oder viel schlimmer ...

Ein echter Vorfall

Im November 2000 erhielten 28 Patienten in einem Krankenhaus in Panama während der Behandlung verschiedener Krebsarten eine massive Überdosis an Gammastrahlen. In den darauffolgenden Monaten starben 5 dieser Patienten an einer Strahlenvergiftung und 15 weitere entwickelten schwere Komplikationen. Wie kam es zu dieser Tragödie? Ein von einem amerikanischen Unternehmen entwickeltes Softwarepaket wurde von den Technikern des Krankenhauses modifiziert, um die Strahlendosen für jeden Patienten zu berechnen.

Die drei panamaischen Medizinphysiker, die die Software verändert hatten, um zusätzliche Funktionen zu erhalten, wurden wegen Mordes zweiten Grades angeklagt. Das US-Unternehmen sieht sich in zwei Ländern mit ernsthaften Rechtsstreitigkeiten konfrontiert.

Gage und McCormick nehmen Stellung:

Dies ist kein abschreckendes Beispiel für Medizintechniker, auch wenn sie selbst darum kämpfen müssen, nicht ins Gefängnis zu kommen, wenn sie die Technologie falsch verstehen oder missbrauchen. Dies ist auch keine Geschichte darüber, wie Menschen durch schlecht konzipierte oder schlecht erklärte Software verletzt werden oder Schlimmeres erleiden können, obwohl es genügend Beispiele gibt, die dies verdeutlichen. Dies ist eine Warnung für alle Entwickler von Computerprogrammen: dass Softwarequalität wichtig ist, dass Anwendungen narrensicher sein müssen und dass - ob im Motor eines Autos, einem Roboterarm in einer Fabrik oder einem Heilgerät in einem Krankenhaus - schlecht implementierter Code tödlich sein kann.

INVESTIGATION OF AN ACCIDENTAL EXPOSURE OF RADIOTHERAPY PATIENTS IN PANAMA

Report of a Team of Experts, 26 May–1 June 2001



INTERNATIONAL ATOMIC ENERGY AGENCY

Risikoanalyse und -management

Proactive Strategy

Risikoanalyse und -management sind Maßnahmen, die einem Softwareteam helfen, Unsicherheiten zu verstehen und zu bewältigen.

1. Identifizieren Risiken
2. Bewerte die Wahrscheinlichkeit ihres Auftretens und ihre Auswirkungen ► Setzen Sie Prioritäten
3. Einen Plan aufstellen: Schadensbegrenzung und Notfallmaßnahmen
4. Überwachung und Aktualisierung

Risikokategorien

Bekannte Risiken

- Identifiziert durch Bewertung des Projektplans, der technischen Herausforderungen und des Geschäftsumfelds

Vorhersehbare Risiken

- Auf der Grundlage von Erfahrungen identifiziert

Unvorhersehbare Risiken

- Können vom Team nicht identifiziert werden

Risikokategorien

Risk type	Source	Impact
Project	Schedule, budget, staffing and organization, resource, stakeholder, requirements problems. The bigger/more complex a project is, the higher project risks it has.	Project plan
Technical	Design, implementation, interface, verification, maintenance. Specification ambiguity, technical uncertainty, technical obsolescence, “leading-edge” technology.	Quality and timeline
Business	Market, business strategy, sales, management, budget.	Viability of the project/product

Identifizierung von Risiken

Eine Checkliste:

- a. Haben sich die obersten Software- und Kundenmanager förmlich verpflichtet, das Projekt zu unterstützen?
- b. Sind die Endbenutzer von dem Projekt und dem zu entwickelndes System/Produkt begeistert?
- c. Werden die Anforderungen vom Softwareentwicklungsteam und seinen Kunden vollständig verstanden?
- d. Wurden die Kunden vollständig in die Definition der Anforderungen einbezogen? Haben die Endnutzer realistische Erwartungen?
- e. Ist der Projektumfang stabil?
- f. Verfügt das Softwareentwicklungsteam über die richtige Mischung von Fähigkeiten?
- g. Sind die Projektanforderungen stabil?
- h. Verfügt das Projektteam über Erfahrung mit der zu implementierende Technologie?
- i. Ist die Anzahl der Mitarbeiter im Projektteam ausreichend, um die Aufgabe zu bewältigen?
- j. Sind sich alle Kunden-/Benutzerkreise über die Bedeutung des Projekts und die Anforderungen an das zu entwickelndes System/Produkt einig?

Identifizierung von Risiken

- k. Ist Ihr Zeitplan realistisch?
- l. Ist der TechStack für Ihre Entwicklung ausreichend?
- m. Ist eine dritte Partei beteiligt? Sind alle rechtlichen Fragen geklärt?
- n. Wenn Open-Source-Code verwendet wird, wurde die Einhaltung der Lizenz überprüft?
- o. Sind Verifizierungskriterien vorhanden?
- p. Integrationstest?
- q. Wird es auf allen gängigen Plattformen eingesetzt?
- r. Sicherheitsrisiken?
- s. Wenn die nächste Version geplant ist, ist das aktuelle Design einfach zu erweitern?

Risikokomponenten

Performancerisiko

der Grad der Unsicherheit, dass das Produkt die Anforderungen erfüllt und für den vorgesehenen Gebrauch geeignet ist.

Kostenrisiko

der Grad der Unsicherheit, ob das Projektbudget eingehalten wird.

Wartungsrisiko

der Grad der Ungewissheit, ob die resultierende Software leicht zu korrigieren, anzupassen und zu verbessern sein wird.

Zeitplanrisiko

der Grad der Unsicherheit, dass der Projektzeitplan eingehalten und das Produkt rechtzeitig geliefert wird.

Risikoeinschätzung

Zwei Merkmale von Risiken:

- Ungewissheit ➤ Wahrscheinlichkeit
- Verlust ➤ Impact

Risiko-Score = Wahrscheinlichkeits-Score × Impact-Score

Priorisiere die Risiken anhand des Risiko-Scores

Wahrscheinlichkeits- und Impact-Score Beispiel

Score	Wahrscheinlichkeit	Impact (Kosten/Zeitaufwand)
Very low: 1	< 1%	< 1% / 1 Tag
Low: 2	< 10%	< 5% / 1 Woche
Medium: 3	< 20%	< 10% / 2Wochen
High: 4	< 50%	< 20% / 1 Monat
Very high: 5	≥ 50%	≥ 20% / 1 Monat

Riskiko-Score Kategorien:

- Catastrophic: ≥ 15
- Serious: ≥ 10
- Medium: ≥ 5
- Low: ≤ 4

Risk Mitigation Plan

Vermeide das Risiko

Mitigation: the act of reducing how harmful, unpleasant, or bad something is

Risk Mitigation bedeutet einfach die Verringerung der negativen Auswirkungen von Risiken, die für das Projekt und die Geschäftskontinuität schädlich sind. Sie umfasst die Einführung von Maßnahmen und Schritten in einem Projektplan, um Risiken zu mindern, zu reduzieren, zu eliminieren oder zu kontrollieren. Risk Mitigation bedeutet, den Eintritt von Risiken zu verhindern (Risikovermeidung).

Risk Contingency Plan

Was ist zu tun, wenn das Risiko tatsächlich eintritt?

Contingency: something that might possibly happen in the future, usually causing problems or making further arrangements necessary

Ein Risk Contingency Plan enthält Richtlinien, die festlegen, was eine Organisation tun sollte, wenn ein hypothetisches Risiko Realität wird. Ihr Ziel ist es, den Schaden zu minimieren, den eine unerwünschte Abfolge von Ereignissen für eine Organisation und ihre Vermögenswerte bedeuten könnte.

Risk Monitoring

- Listet alle Indikatoren für Risiken auf
- Habt (mindestens) eine Person die verantwortlich ist
- Aktualisiert den Status von Risiken

Risk Mitigation, Monitoring and Management (RMMM)

Id	Risk description	Probability (P)	Damage (D)	Risk score (P x D)	Mitigation strategy	Indicator	Contingency plan	Status	Responsible	Update date

Diese Tabelle ist ein lebendes Dokument

Zusammenfassung

Proactive Strategy

Risikoanalyse und -management sind Maßnahmen, die einem Softwareteam helfen, Unsicherheiten zu verstehen und zu bewältigen.

1. Identifizieren Risiken ➤ Verwende die Checkliste
2. Bewerte die Wahrscheinlichkeit ihres Auftretens und ihre Auswirkungen ➤ Setzen Sie Prioritäten
3. Einen Plan aufstellen:
 - Mitigation ➤ vermeide das ein Risiko auftritt
 - Contingency ➤ Was ist zu tun, wenn ein Risiko auftritt
4. Überwachung und Aktualisierung ➤ Habt eine verantwortliche Person und aktualisiert den Status von Risiken